Cyber.SoHo Educational Hub
From the Industry to the Classroom

Readiness, Register, Rank

Response capability, the risk matrix and register, and prioritization

420-1C2-DW Threats and Risks · Class 11

Topic 5 — Assessing Probability and Impact (Part 2)

Saturday, November 14, 2026 · 2:00 – 6:00 pm · Online

The one fact to remember

> **A risk is managed only when it is written in the register with its evidence, its owner and its rank.**

Corner of the screen all hour: **evidence · owner · rank**

Tonight's hour — three lessons on the clock

0:00 – 0:04	Opening — the one fact, objectives, legal notice
0:04 – 0:22	**Lesson 1 — The organization's ability to respond to an incident**
0:22 – 0:42	**Lesson 2 — The risk matrix and the risk register**
0:42 – 0:56	**Lesson 3 — Prioritizing threats to assets**
0:56 – 1:00	Lab 2 due tonight · Lab 3 starts · recap

By the end of this hour you will be able to

1. Assess an organization's ability to respond to an incident with a readiness scorecard and the time measures **MTTD** (mean time to detect), **MTTC** (mean time to contain), **MTTR** (mean time to recover), **RTO** (recovery time objective) and **MTD** (maximum tolerable downtime), and explain how response capability changes the impact of a scenario (EZ02, criterion 4.6).
2. Read and design a 5 × 5 risk matrix, explain its bands and its limits, and distinguish inherent, current, residual and target risk, risk appetite and risk tolerance.
3. Write correct risk register rows: scenario statement, assets, threat, risk factors, controls, ratings with justification, readiness, owner, status and review date, each with its evidence.
4. Prioritize threats to assets with a documented method — class, score, impact, asset criticality, threat evidence, readiness — and an escalation rule (EZ02, criterion 4.1).
5. Explain what Lab 3 asks and how tonight's three outputs become its starting rows.

Legal and ethical notice — read before any lab

- All data, people and systems tonight are fictional (Kalmia Coffee Roasters Inc.).
- Nothing is scanned, tested or contacted: we rate, record and rank risks.
- Read public catalogues (**KEV** [Known Exploited Vulnerabilities catalog], **EPSS** [Exploit Prediction Scoring System], **CVSS** [Common Vulnerability Scoring System]); never test a listed vulnerability (section 7.3).
- A risk register shows where a company is weak: keep it confidential (sections 6.7 and 17).
- Your ratings and justifications are your own work (section 18, **ISEP** [Institutional Student Evaluation Policy]).
- Check every link before clicking — VirusTotal (section 14, Annex C).

§

Legal Notice v2.0 — sections 6.7 · 7.3 · 14 · 17 · 18

Full terms: Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy (v2.0)

Kalmia — where we are in the Integrative Project

Lab 1
Assets & map

done

Lab 2
Threat catalogue

due tonight

Lab 3
Risk register & priorities

starts now

Lab 4
Treatment & prevention plan

Nov 20 → 26

Inputs tonight: 34 risk factors KRF-01 to KRF-34 and 5 unknowns (Class 9); five scenarios R-01 to R-05 rated in Class 10.

1

Lesson 1 — The organization's ability to respond to an incident

Why response capability changes impact, what it is made of, how to measure it, and the legal clock in Québec

0:04 – 0:22

1 Same attack, different outcome

- Two roasters, the same ransomware, the same Saturday night.
- Roaster A: written plan, alert that wakes someone, backup kept away from the network → back the same evening.
- Roaster B: none of these → disrupted for almost a week.
- Same threat, same vulnerability, same likelihood — **different impact**.
- Impact depends on **how long** the disruption lasts and **how far** it spreads.
- Response capability = detective + corrective controls: it mainly lowers impact (**ISO** [International Organization for Standardization] 31000).
- EZ02, criterion 4.6: a **realistic** assessment — based on evidence, not intentions.

10 h vs 6 days

same ransomware, two very different outages

1 Event, incident and incident response

- **Security event** — any observable occurrence (a sign-in, a firewall block, a file change).
- **Security incident** — actually or imminently jeopardizes confidentiality, integrity or availability, or violates a policy.
- **Incident response** — detect, analyze, contain, eradicate, recover, learn.
- **NIST** (National Institute of Standards and Technology, United States) **SP** (Special Publication) 800-61 Revision 3 (April 2025): incident response inside risk management, organized by the six **CSF** (Cybersecurity Framework) 2.0 Functions.
- **ISO/IEC** (International Organization for Standardization / International Electrotechnical Commission) 27035-1:2023: plan and prepare · detect and report · assess and decide · respond · learn lessons.
- For risk: each phase takes time — the sum is the outage.

event ≠ incident

most events are harmless; an incident jeopardizes C, I or A

1 The response lifecycle and the CSF 2.0 Functions



Detect, contain and recover (rust) are the three timed phases of the outage model.

1 Four components of the ability to respond

Four components of the ability to respond — Kalmia today

Evidence: Class 9 risk factors and unknowns

Four components of the ability to respond — and Kalmia today

People	Process	Technology	Partners & law
Good: Roles, backup person, on-call	Good: Approved plan, playbooks, decisions	Good: Alerts read, isolation, tested off-site copy	Good: MSP hours, insurance, CAI notice, register
Kalmia: KRF-32: one half-time coordinator, no backup	Kalmia: KRF-19: no incident response plan	Kalmia: KRF-17 flat network · KRF-21 connected backup	Kalmia: InfoNord business hours · U-05
C2 = 1	C1 = 0 · C8 = 0	C3 = 1 · C4 = 0 · C5 = 1	C6 = 1 · C7 = 1

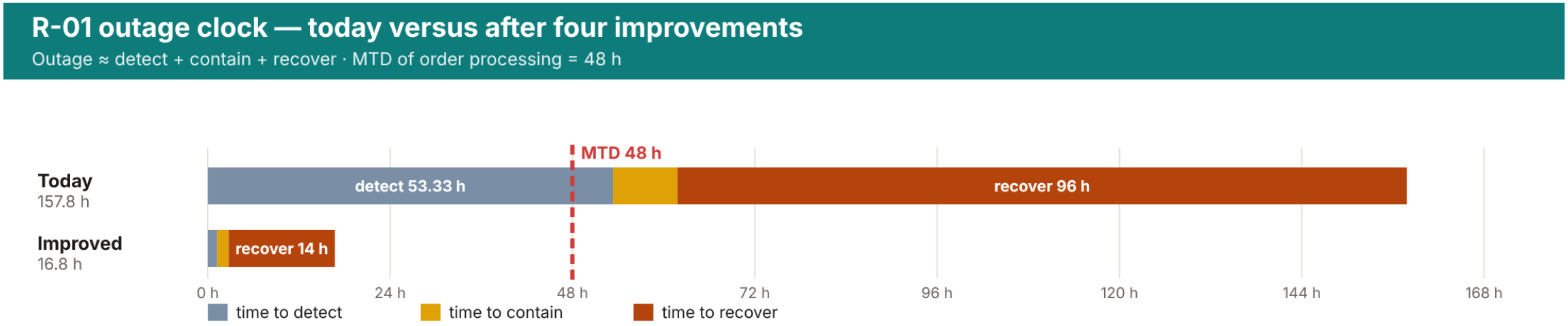
Each gap is a risk factor from Thursday's list (**KRF** [Kalmia risk factor]) or an unknown (U).

1 Measuring the ability to respond in hours

Measure	What it means
MTTD (mean time to detect)	average time from the start of an incident to its detection
MTTC (mean time to contain)	average time from detection to containment
MTTR (mean time to recover)	average time to restore normal service (define it: recover, repair or respond)
RTO (recovery time objective)	target maximum time to restore a process (from the **BIA** [business impact analysis])
RPO (recovery point objective)	maximum acceptable data loss, measured in time
MTD (maximum tolerable downtime)	longest tolerable outage of a process; the **RTO** must be shorter

Kalmia: **MTD** of order processing = 48 h (set by Karim Haddad for this example).

1 The outage model: detect + contain + recover versus the MTD



R-01 today ≈ 158 h (6.6 days) → operations level 5. After four improvements ≈ 16.8 h → level 3.

1 A realistic score: the readiness scorecard (0 to 3)

Score	Name	Meaning
0	Absent	The capability does not exist.
1	Informal	It exists in someone's head, as a draft or as a habit; it is not written and approved, or it has a known weakness.
2	Documented	It is written, approved by management and known by the people who must use it.
3	Tested	It is documented and approved, and a test in the last 12 months (exercise, restore test) proved that it works.

Eight capabilities C1–C8 · readiness = total / 24 · 0–33 % LOW · 34–66 % MODERATE · 67–100 % HIGH (course rule). A 3 needs a test record from the last 12 months.

1 The legal clock: Law 25 (Québec) and PIPEDA (Canada)

- **Confidentiality incident** (Québec): unauthorized access, use or communication of personal information, or its loss.
- Reduce the risk of injury — always.
- **Risk of serious injury** → notify the **CAI** (Commission d'accès à l'information du Québec, the Québec privacy regulator) and the persons concerned, promptly.
- Keep a **register of confidentiality incidents** — all of them — and give it to the **CAI** on request (since September 22, 2022).
- **PIPEDA** (Personal Information Protection and Electronic Documents Act): report breaches with a **real risk of significant harm** to the **OPC** (Office of the Privacy Commissioner of Canada); notify individuals; keep records two years.
- Kalmia: U-05 — the serious-injury assessment of INC-04 was never documented → C7 = 1.

CAI

notify promptly when there is a risk of serious injury

1 Key terms — Lesson 1

Security event
Any observable occurrence in a system or a network; most events are harmless.

Security incident
An occurrence that actually or imminently jeopardizes the confidentiality, integrity or availability of information or a system, or violates a security policy.

Incident response
The organized actions taken to detect, analyze, contain, eradicate, recover from and learn from an incident.

Response capability
The people, processes, technology and partners that let an organization respond; a set of detective and corrective controls that mainly reduces impact.

Incident response plan (IRP [incident response plan])
The written and approved document that sets roles, contacts, decisions, steps and communications for incidents.

Playbook
A step-by-step procedure for one type of incident, for example ransomware.

MTTD (mean time to detect) / MTTC (mean time to contain) / MTTR (mean time to recover)
Average times to detect, to contain and to recover; their sum approximates the outage.

RTO (recovery time objective) / RPO (recovery point objective)
Target time to restore a process; maximum acceptable data loss measured in time.

1 Micro-activity — Clock the outage (3 min)

?

Incident INC-03 (August): a café's card payments stopped for two hours. The manager noticed after 20 minutes, called the **POS** (point of sale) provider, waited 40 minutes for an answer, and the service returned one hour later. (1) Split the two hours into detect, contain and recover. (2) Which capability of the scorecard would have shortened the first part? (3) Does the outage exceed what the café could tolerate if its **MTD** (maximum tolerable downtime) is four hours?

Work alone, then compare with your neighbour. The answer is shown after the timer.

1 Lesson 1 — videos, flash-cards and quiz

Incident Response — CompTIA Security+ SY0-701 — 4.8

Professor Messer · 9:14

Watch on YouTube

Incident Planning — CompTIA Security+ SY0-701 — 4.8

Professor Messer · 6:50

Watch on YouTube

Business Impact Analysis — CompTIA Security+ SY0-701 — 5.2

Professor Messer · 2:55

Watch on YouTube

In the module: five flash-cards and a formative quiz (4 multiple-choice + 2 multiple-select) — practice only, not evaluated. All videos confirmed working on November 11, 2026; each 15 minutes or shorter.

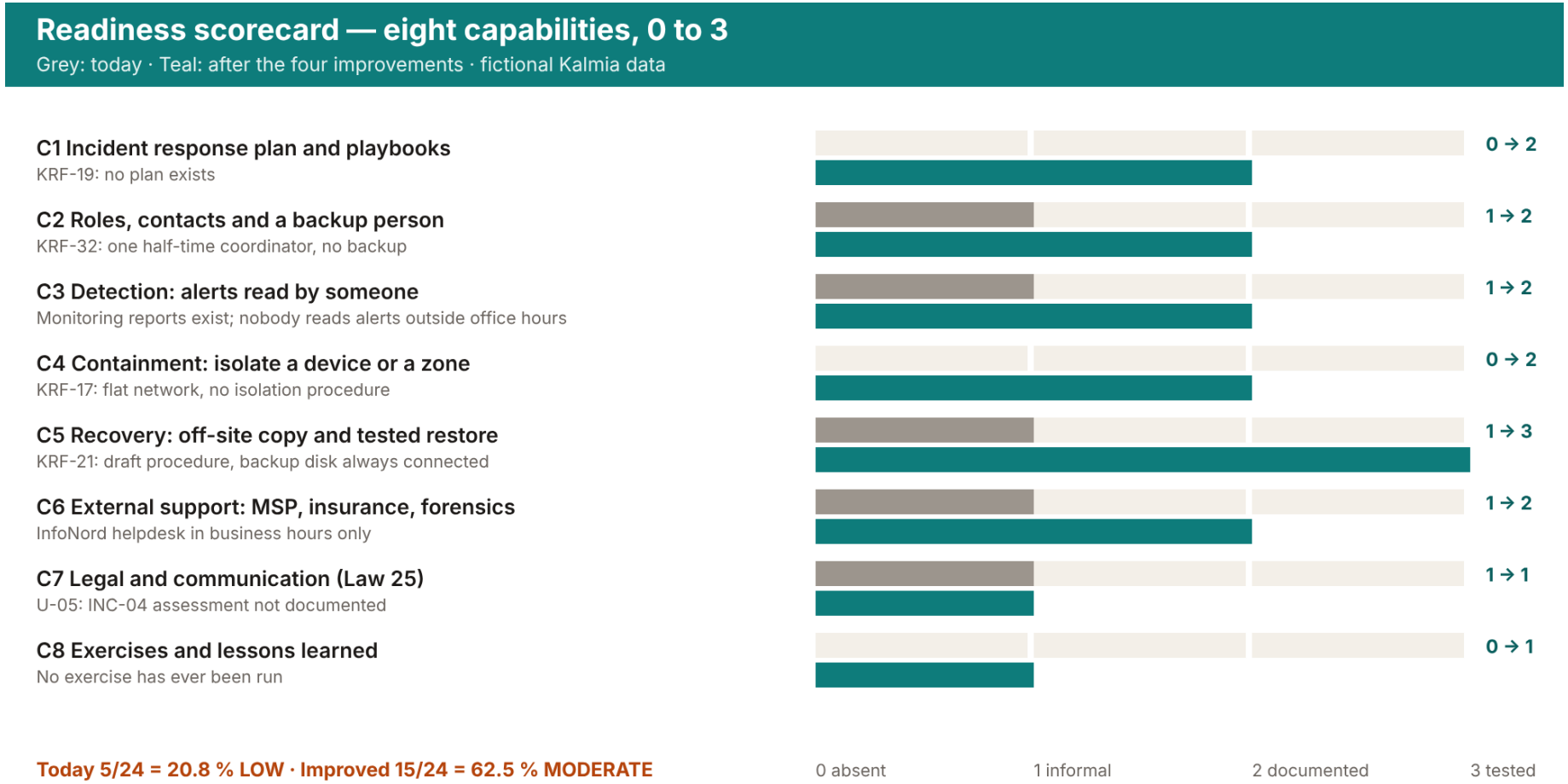
1 Real-life example 1 — Saturday 02:10, ransomware on NAS-01

- Task: score the eight capabilities, estimate the R-01 outage today and after four improvements, compare with the 48-hour **MTD** (maximum tolerable downtime), derive the response-adjusted impact.
- Lucas Martin: half-time, Monday to Friday · InfoNord: business hours · backup disk always connected.
- Today: readiness 5/24 = 20.8 % (LOW) · outage ≈ 158 h · impact 5 · score 20 CRITICAL.
- Improvements: plan + on-call · mass-change alert · isolation procedure · tested off-site copy.
- Improved: readiness 15/24 = 62.5 % (MODERATE) · outage ≈ 16.8 h · impact 3 · score 12 HIGH.
- Likelihood stays 4: the phishing e-mail still arrives.
- Lab 3: “Response readiness” and “Impact justification” columns (ir_readiness.csv, ir_timeline.csv).

20 → 12

R-01 score today → after four improvements

1 Real-life example 1 — the readiness scorecard, today and improved



Grey: today (5/24, LOW). Teal: after the four improvements (15/24, MODERATE).

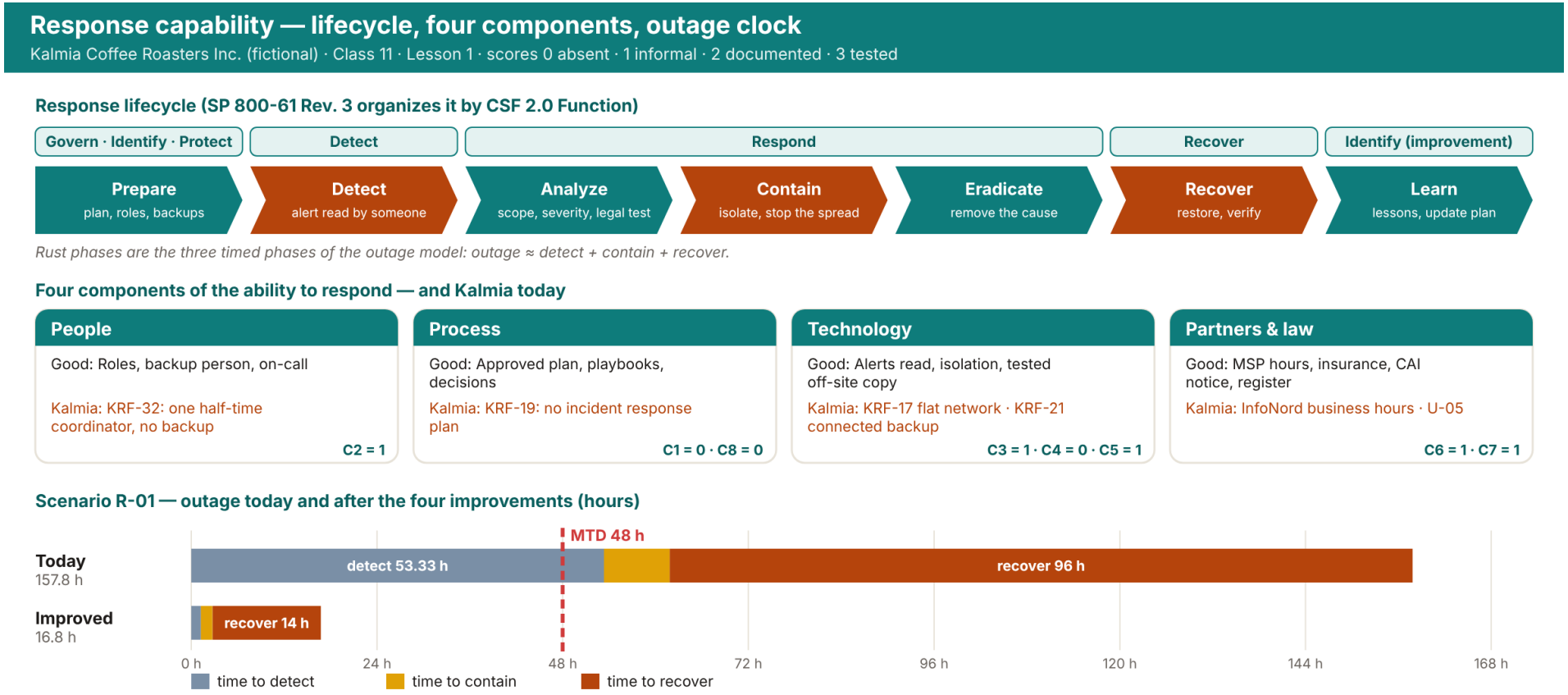
1 Code example 1 — readiness scorecard and outage clock (Python)

- kalmia_ir_readiness.py — Python 3.8+, standard library only.
- Scores the eight capabilities twice (today, improved) and prints each line.
- Readiness % = total / 24 → LOW · MODERATE · HIGH.
- Outage = detect + contain + recover → compared with the **MTD** (maximum tolerable downtime).
- Operations, money (**SLE** [single loss expectancy]) and personal information → the highest level is the impact.
- Writes ir_readiness.csv and ir_timeline.csv for the Lab 3 register.
- In the module: Start / Pause / Step / Restart replay a real recorded execution, line by line.

161

recorded steps, replayed line by line in the module

1 Schematic 1 — response capability: lifecycle, components, outage clock



Downloadable from the module as SVG or PNG.

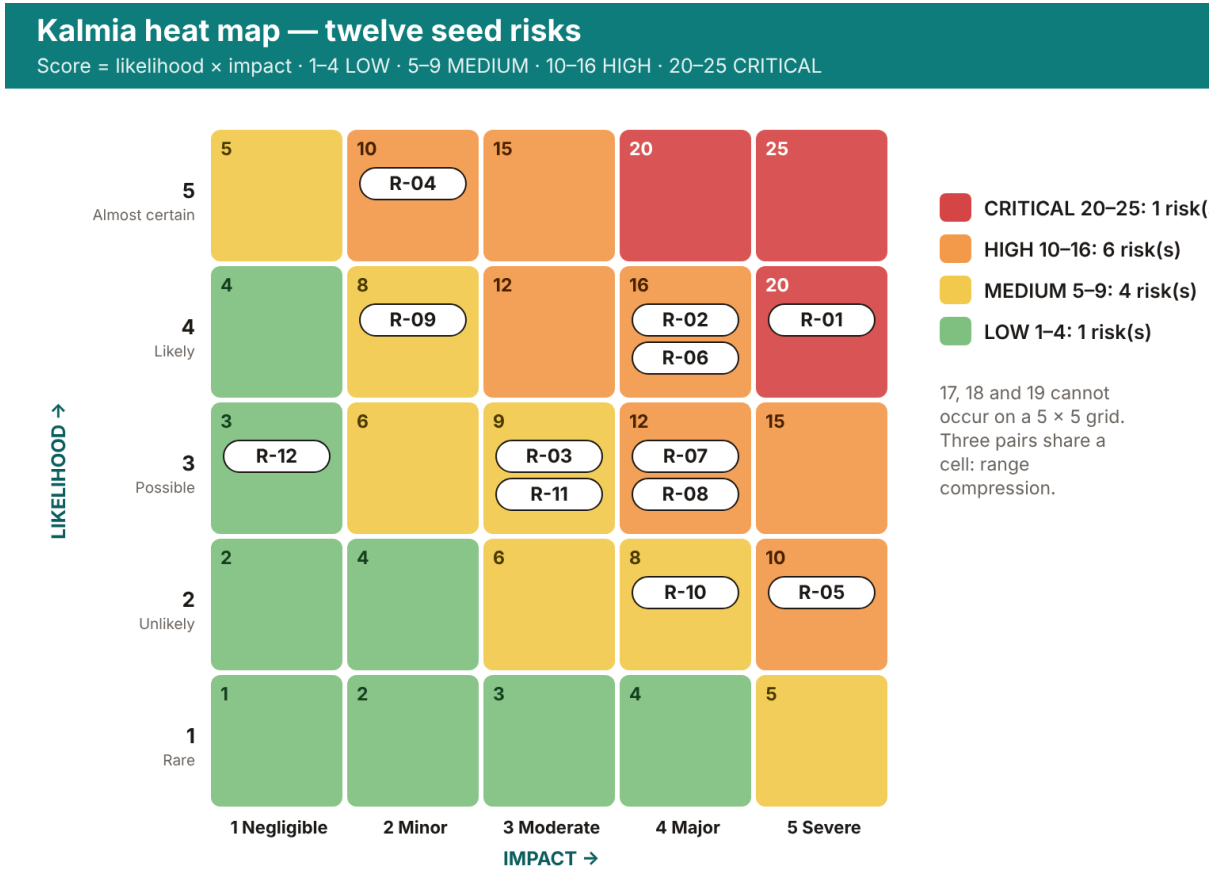
2

Lesson 2 — The risk matrix and the risk register

Reading and designing a 5 × 5 matrix, its limits, risk appetite, and the columns and rules of a correct register

0:22 – 0:42

2 The Kalmia 5 × 5 matrix and its four bands



Score = likelihood × impact · 1–4 LOW · 5–9 MEDIUM · 10–16 HIGH · 20–25 CRITICAL · 17–19 cannot occur.

2 Designing a matrix: grids, asymmetry, lookup tables

- Grids of 3 × 3, 4 × 4 or 5 × 5 — the scales are written before the rating starts.
- **Asymmetric** matrices give impact more weight: every severe impact is at least HIGH.
- **NIST** (National Institute of Standards and Technology, United States) **SP** (Special Publication) 800-30 Revision 1 (Appendix I): a level-of-risk table that combines qualitative levels, without multiplying.
- **OWASP** (Open Worldwide Application Security Project) Risk Rating: likelihood and impact from 0 to 9 → LOW, MEDIUM, HIGH → a 3 × 3 severity table.
- No design is “the correct one”: the same scales and bands must be used for every risk.

5 × 5

Kalmia: symmetric grid, score = likelihood × impact

2 What a matrix cannot do (Cox, 2008)

- Levels are **ordinal**: they give an order, not a distance — 16 is not “twice” 8.
- **Range compression**: very different risks share a cell or a band (10 and 16 are both HIGH).
- A matrix can even rank a quantitatively smaller risk higher.
- Cox (Risk Analysis, 2008): use matrices with caution and explain the judgments built into them.
- Kalmia keeps L and I separately, the score, the justification, the evidence, the confidence — and an **ALE** (annualized loss expectancy) for the top risks.
- The matrix shows the picture; the register holds the reasons.

10 = 10?

R-04 (5 × 2) and R-05 (2 × 5): same score, different risks

2 Inherent, current, residual and target risk

Moment	Definition	At Kalmia
Inherent	risk if no control existed	theoretical reference
Current	risk with today's controls	what Lab 3 rates
Residual	risk remaining after treatment	Topic 6; R-01 ≈ 12 after the four improvements
Target	level management wants, by a date	set with the owner

2 Risk appetite, risk tolerance and Kalmia's decision rules

Band	Scores	Decision rule	Review
LOW	1–4	Accept and monitor	12 months
MEDIUM	5–9	Owner named; decision within 90 days	6 months
HIGH	10–16	Treatment plan within 30 days	Monthly
CRITICAL	20–25	Action within 7 days; weekly report to the **CEO** (chief executive officer)	Weekly

Appetite: the amount and type of risk an organization is willing to pursue or retain (**ISO** [International Organization for Standardization] 31073). Tolerance at Kalmia: no outage of order processing longer than 48 h.

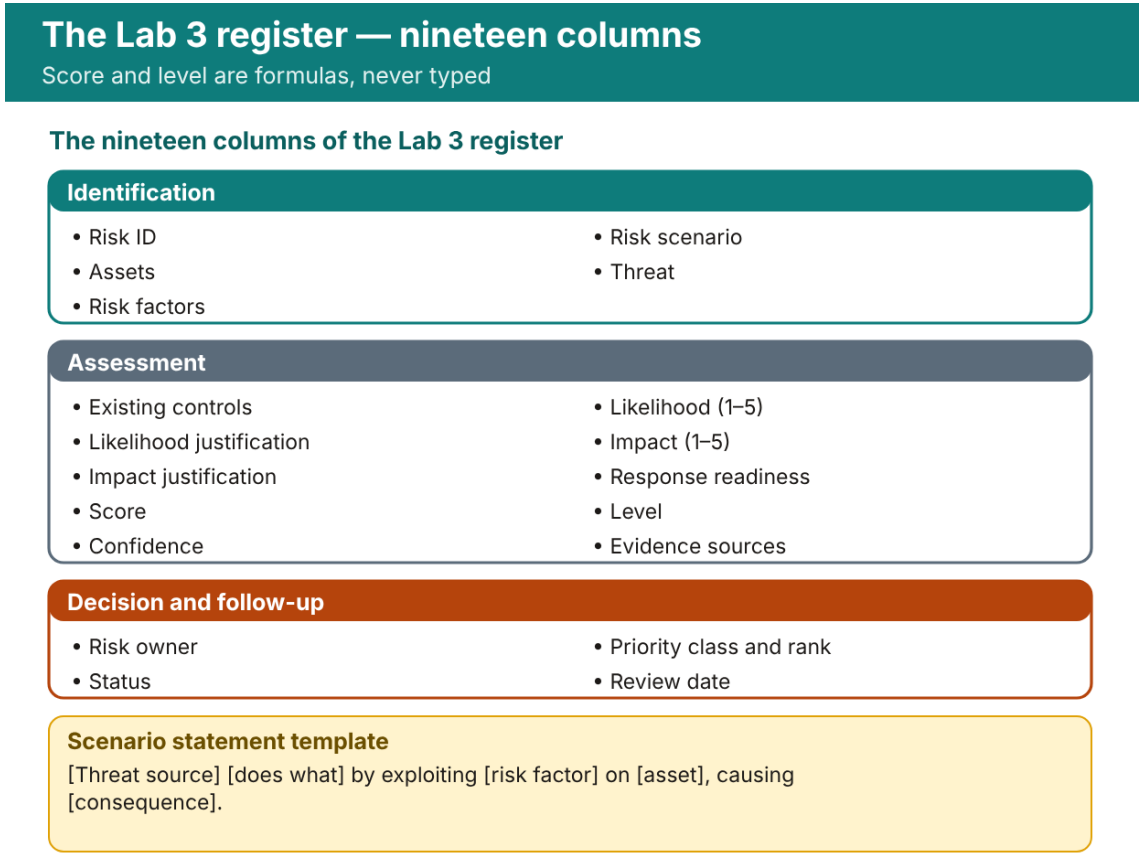
2 The risk register: definition and five purposes

- **Risk register**: a record of information about identified risks (**ISO** [International Organization for Standardization] 31073).
- **NIST** (National Institute of Standards and Technology, United States) **IR** (Interagency or Internal Report) 8286 Revision 1 and IR 8286A Revision 1 (December 2025): the **cybersecurity risk register** (**CSRR** [cybersecurity risk register]) rolls up into the enterprise register.
- Five purposes: **decision** · **accountability** · **traceability** · **follow-up** · **communication**.
- A living document: HIGH and CRITICAL reviewed monthly, others every six months, and after every incident.
- **Risk owner** = the manager accountable and authorized to decide — not the technician who fixes.
- Kalmia owners: Nadia Roy · Karim Haddad · Sophie Tremblay.

19

columns in the Lab 3 register

2 The nineteen columns of the Lab 3 register



- **Identification** — who or what, through which weakness, to which asset (5 columns).
- **Assessment** — controls, likelihood, impact, readiness, score, level, confidence, evidence (10 columns).
- **Decision and follow-up** — owner, priority and rank, status, review date (4 columns).
- Score and level are formulas: they can never contradict the ratings.
- Lesson 3 adds two inputs next to them: criticality and threat_evidence.

Score and level are formulas, never typed. Two ranking inputs (criticality, threat evidence) sit next to them.

2 Writing a risk scenario statement

Not a scenario

- “Ransomware” — no asset, no weakness, no consequence.
- “Weak passwords” — a risk factor, not a risk.
- “Hackers could attack Kalmia” — too vague to rate.

A scenario

- [Source] [does what] by exploiting [risk factor] on [asset], causing [consequence].
- R-01: a ransomware group enters through a phished **PC** (personal computer), uses the shared NAS-01 password and the flat network, encrypts the shares and the connected backup — orders stop for days.

Quality rules: one scenario per row · evidence for every rating · owner = manager · level agrees with the matrix · fictional and confidential.

2 Key terms — Lesson 2

Risk matrix (heat map)
A grid crossing likelihood and impact levels; each cell receives a risk level.

Band
A range of scores that receives one level and one decision rule (LOW, MEDIUM, HIGH, CRITICAL).

Ordinal scale
A scale whose numbers give an order but not a distance; multiplying ordinal levels is a convention.

Range compression
Different risks receiving the same cell or band, which hides real differences between them.

Inherent / current / residual / target risk
Risk without controls / with today's controls / after treatment / desired level by a date.

Risk appetite
The amount and type of risk an organization is willing to pursue or retain.

Risk tolerance
The readiness to bear a risk after treatment; a narrower limit for one objective or category.

Risk register
A record of information about identified risks; the one table where risks are described, rated, owned and followed.

2 Micro-activity — Fix the row (3 min)

?

R-13 | Hackers | Web | L=3 | I=4 | Score=7 | Level=MEDIUM | Owner=Lucas Martin | Evidence= (empty). Find at least four errors and correct them.

Work alone, then compare with your neighbour. The answer is shown after the timer.

2 Lesson 2 — videos, flash-cards and quiz



Risk Analysis — CompTIA Security+ SY0-701 — 5.2

Professor Messer · 9:13

Watch on YouTube



Risk Management — CompTIA Security+ SY0-701 — 5.2

Professor Messer · 3:30

Watch on YouTube

In the module: five flash-cards and a formative quiz (4 multiple-choice + 2 multiple-select) — practice only, not evaluated. All videos confirmed working on November 11, 2026; each 15 minutes or shorter.

2 Real-life example 2 — twelve seed rows (1/2)

ID (identifier)	Risk (short)	L	I	Score → level	Owner
R-01	Ransomware encrypts the NAS-01 shares	4	5	20 → CRITICAL	Karim Haddad
R-02	Former employee's account exports loyalty records	4	4	16 → HIGH	Sophie Tremblay
R-03	Fraudulent supplier bank change is paid	3	3	9 → MEDIUM	Sophie Tremblay
R-04	Café card payments stop (single link)	5	2	10 → HIGH	Karim Haddad
R-05	FW-HQ administration portal taken over	2	5	10 → HIGH	Karim Haddad
R-06	Web shop administrator account taken over	4	4	16 → HIGH	Nadia Roy

2 Real-life example 2 — twelve seed rows (2/2)

ID (identifier)	Risk (short)	L	I	Score → level	Owner
R-07	Vendor remote access to ROAST-PC misused	3	4	12 → HIGH	Karim Haddad
R-08	NAS-01 disk failure during a power cut	3	4	12 → HIGH	Karim Haddad
R-09	Cameras CAM-HQ-3 and CAM-HQ-4 hijacked	4	2	8 → MEDIUM	Karim Haddad
R-10	Intruder enters the server closet	2	4	8 → MEDIUM	Karim Haddad
R-11	Sales laptop lost or stolen	3	3	9 → MEDIUM	Karim Haddad
R-12	Gift-card fraud through phishing texts	3	1	3 → LOW	Sophie Tremblay

1 CRITICAL · 6 HIGH · 4 MEDIUM · 1 LOW. Ties: R-02/R-06 (16), R-07/R-08 (12), R-04/R-05 (10).

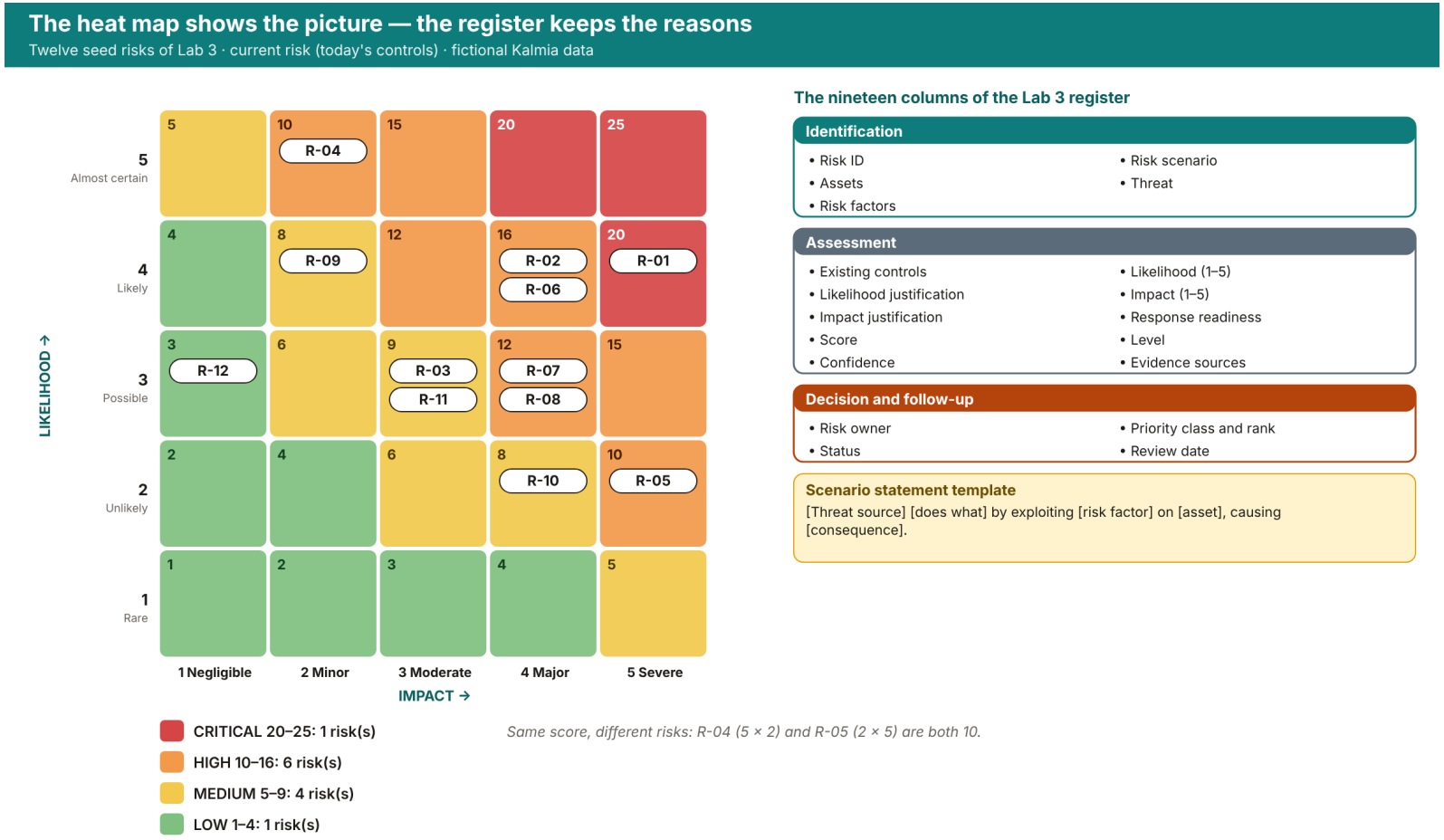
2 Code example 2 — register builder, checker and heat map (Python)

- kalmia_risk_register.py reads kalmia_seed_scenarios.csv (or your file).
- Checks nine quality rules per row: identifier, required columns, statement length, ratings 1–5, owner, readiness, status, review date, typed score.
- Computes score and level; places each correct row in its cell of the heat map.
- Writes kalmia_risk_register.csv and risk_matrix.csv; prints the matrix and RESULT.
- Lab 3: python3 kalmia_risk_register.py your_register.csv --lab3 → RESULT: READY TO SUBMIT.
- In the module: a real recorded execution, line by line, with the heat map filling up.

READY

what the checker must print before you submit Lab 3

2 Schematic 2 — the heat map and the register columns



Downloadable from the module (SVG or PNG); the Lab 3 workbook builds the same heat map with formulas.

3

Lesson 3 — Prioritizing threats to assets

Priority versus level, a documented ranking method with tie-breakers, priority classes, and threat signals (**CVSS** [Common Vulnerability Scoring System], **EPSS** [Exploit Prediction Scoring System], **KEV** [Known Exploited Vulnerabilities catalog], **SSVC** [Stakeholder-Specific Vulnerability Categorization])

0:42 – 0:56

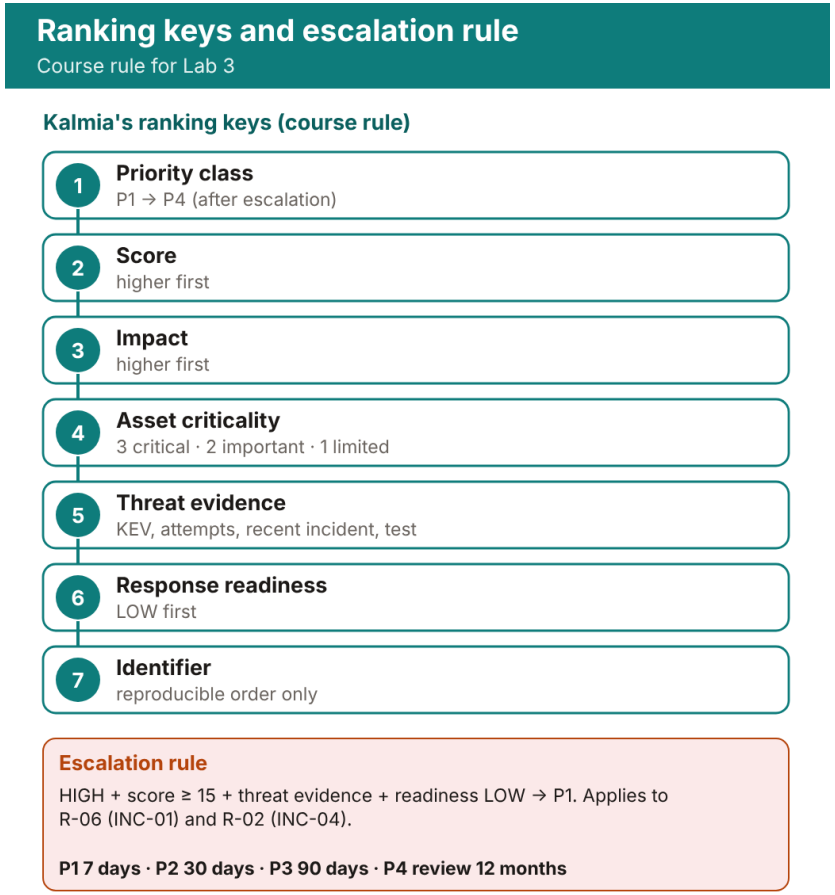
3 Why prioritize — and why a priority is not a level

- One half-time coordinator, an **MSP** (managed service provider) paid by the hour, a limited budget: not twelve risks at once.
- **Prioritization**: the documented order of treatment — greatest harm to the most important assets first.
- EZ02: “proper prioritization of threats to assets” (4.1) and “effective priority management”.
- **Level** comes from the matrix; **priority** adds asset criticality, active threats, readiness and deadlines.
- **NIST** (National Institute of Standards and Technology, United States) **IR** (Interagency or Internal Report) 8286B: priority set by the potential impact on enterprise objectives, recorded in the register.
- A good method: written before use · same order whoever applies it · every position explainable.

12 risks

one half-time coordinator, six weeks before the holidays

3 Kalmia's method: sort first, then break ties



- The next key is used only when all previous keys are equal.
- R-05 before R-04: same class and score (10) — impact 5 beats 2.
- R-08 before R-07: same class, score, impact and criticality — R-08 has active evidence (MR-03, MR-04).
- R-06 before R-02: same class, score (16) and impact — the web shop is critical (3), the loyalty database important (2).
- Two extra register columns hold the inputs: criticality and threat_evidence.

Lexicographic ordering: the next key is used only when all previous keys are equal.

3 Priority classes, deadlines and the escalation rule

Class	Assigned to	Deadline (from Nov 14, 2026)
P1	CRITICAL, or HIGH escalated	November 21, 2026
P2	HIGH	December 14, 2026
P3	MEDIUM	February 12, 2027
P4	LOW	review November 14, 2027

Escalation (course rule): HIGH + score ≥ 15 + threat evidence + readiness LOW → P1. Applies to R-06 (INC-01) and R-02 (INC-04); not to R-08 (score 12).

3 Threat signals: CVSS, EPSS, KEV and SSVC

Signal	Maintained by	Question it answers
CVSS (Common Vulnerability Scoring System)	**FIRST** (Forum of Incident Response and Security Teams)	How severe is the weakness? (0–10; severity, not risk)
EPSS (Exploit Prediction Scoring System)	**FIRST**	How likely is exploitation in the next 30 days? (0–1)
KEV (Known Exploited Vulnerabilities catalog)	**CISA** (Cybersecurity and Infrastructure Security Agency, United States)	Is it already exploited in the wild? (CVE-2017-7921, March 5, 2026)
SSVC (Stakeholder-Specific Vulnerability Categorization)	**CISA** with the **SEI** (Software Engineering Institute, Carnegie Mellon University)	What do we do? Track · Track* · Attend · Act

They feed the likelihood justification and the “threat evidence” key — none replaces the register.

3 Communicating the priorities: the top five for Nadia Roy

- For each risk: rank and level · consequence in plain language · owner · deadline · first action considered.
- Technical identifiers (**CVE** [Common Vulnerabilities and Exposures], vectors, host names) go into an annex.
- Kalmia's top five: R-01, R-06, R-02, R-08, R-07.
- They cover the two company-stopping scenarios, the two Law 25 risks, and the production line.
- The message is confidential (Legal Notice, section 17).

Top 5

plain language · owner · deadline · first action

3 Key terms — Lesson 3

Prioritization
The documented ordering of risks for treatment, so that the greatest potential harm to the most important assets is treated first.

Priority versus level
The level comes from the matrix; the priority also uses asset criticality, threat evidence, readiness and deadlines.

Lexicographic ordering
Sorting on a first criterion and using the next one only to separate risks that are equal on all previous criteria.

Tie-breaker
A criterion used to order two risks with the same score: impact, criticality, evidence, readiness.

Asset criticality
How much the business depends on an asset (3 critical, 2 important, 1 limited), from the Lab 1 business impact analysis.

Threat evidence
Proof that a threat is active: **KEV** (Known Exploited Vulnerabilities catalog) listing, observed attempts, a recent incident on the asset, or success in a test.

Priority class
P1 to P4, each with a deadline taken from the risk appetite.

Escalation rule
Kalmia course rule: a HIGH risk with score ≥ 15, active threat evidence and LOW readiness becomes P1.

3 Micro-activity — Break the tie (2 min)

?

R-03 (fraudulent bank change: L3 × I3 = 9, criticality 2, evidence INC-02, readiness MODERATE) and R-11 (sales laptop lost: L3 × I3 = 9, criticality 1, no evidence, readiness LOW). Which one goes first, and which key decides?

Work alone, then compare with your neighbour. The answer is shown after the timer.

3 Lesson 3 — videos, flash-cards and quiz

Analyzing Vulnerabilities — CompTIA Security+ SY0-701 — 4.3

Professor Messer · 10:29

Watch on YouTube

Risk Management Strategies — CompTIA Security+ SY0-701 — 5.2

Professor Messer · 3:12

Watch on YouTube

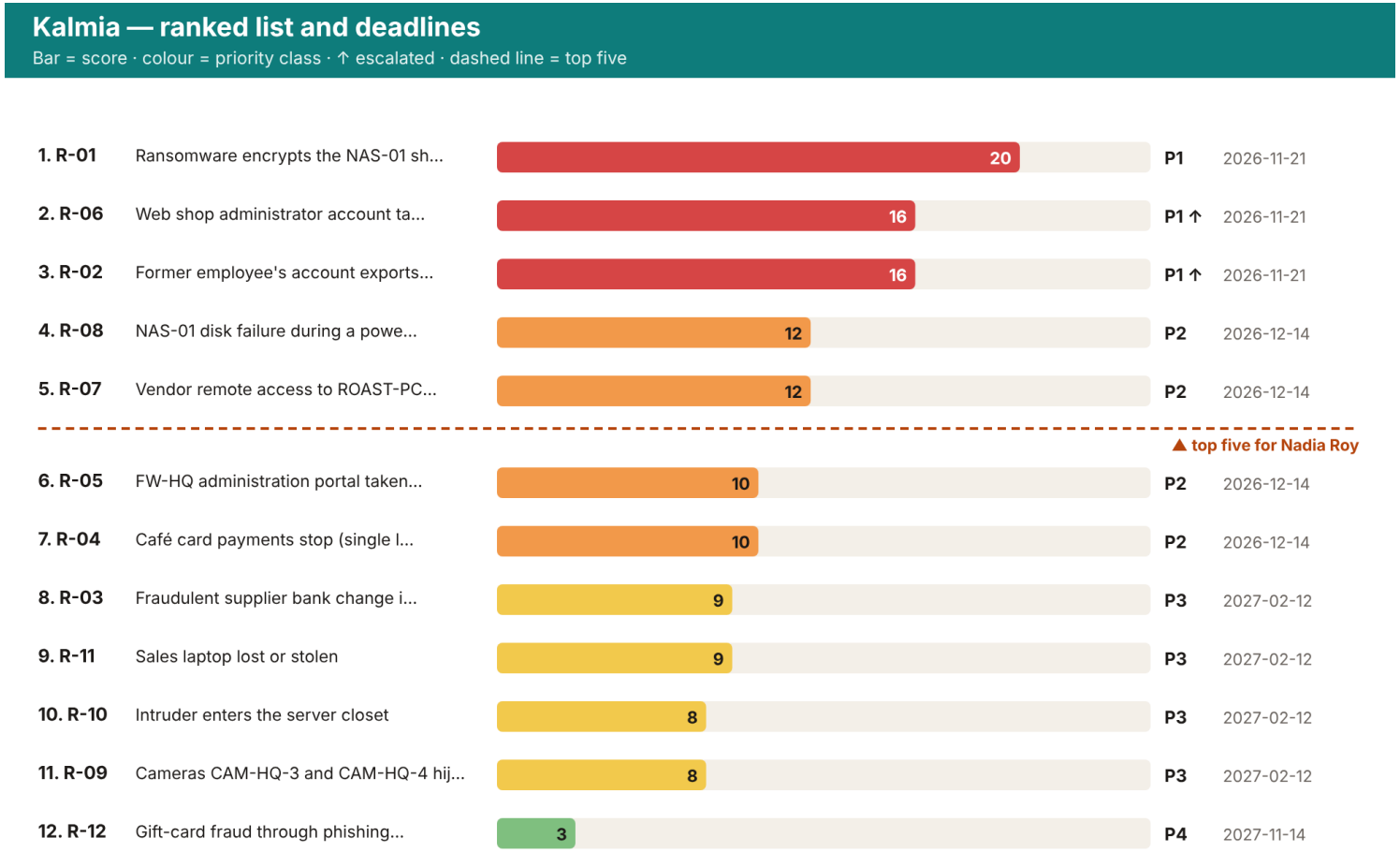
Vulnerability Remediation — CompTIA Security+ SY0-701 — 4.3

Professor Messer · 8:45

Watch on YouTube

In the module: five flash-cards and a formative quiz (4 multiple-choice + 2 multiple-select) — practice only, not evaluated. All videos confirmed working on November 11, 2026; each 15 minutes or shorter.

3 Real-life example 3 — the ranked list and its deadlines



R-06 above R-02 (critical asset) · R-08 above R-07 (active evidence) · R-05 above R-04 (higher impact).

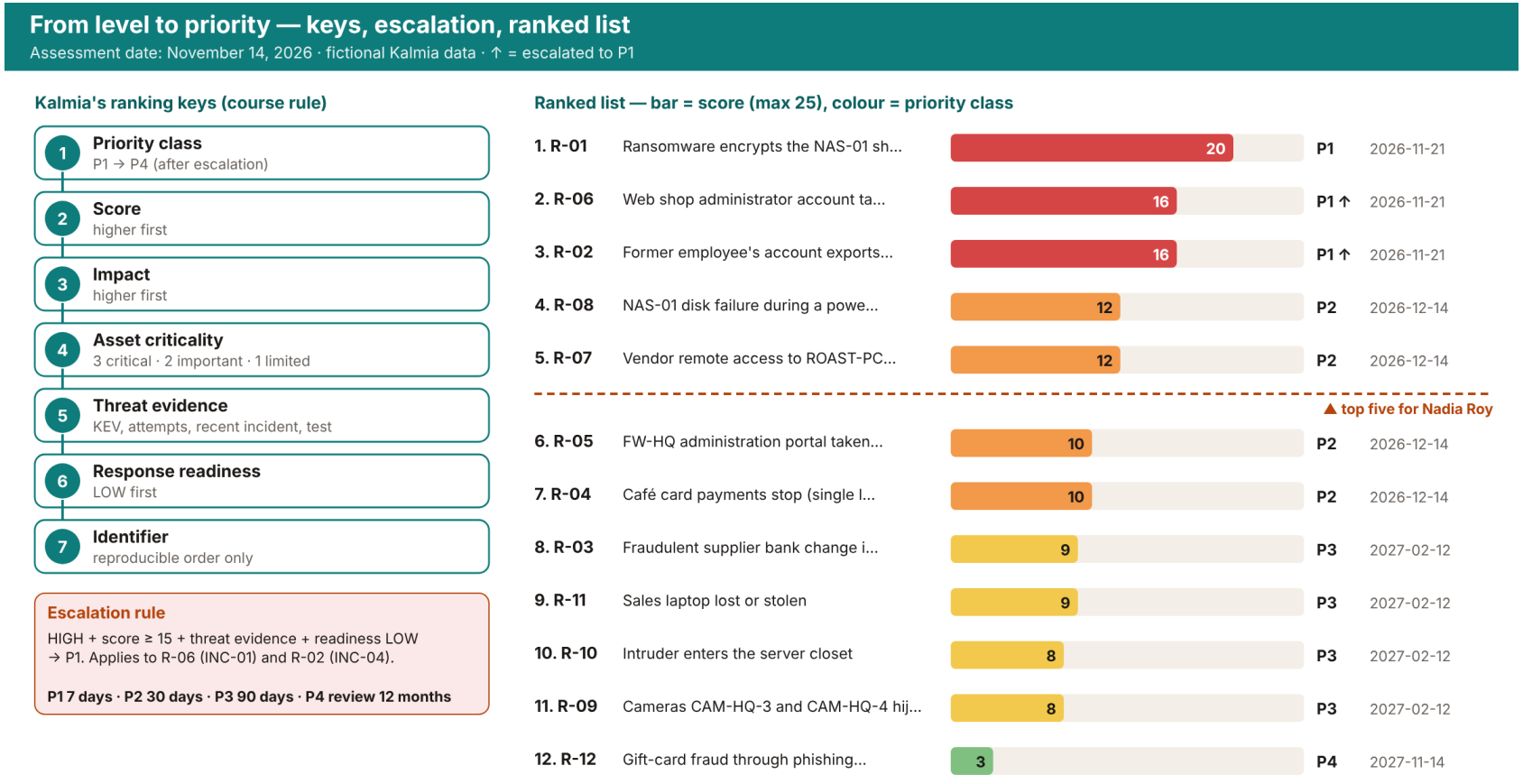
3 Interactive example 3 — the prioritizer (self-contained HTML)

- kalmia_prioritizer.html — opens in any browser, works offline.
- Plan: score, level and base class of each risk; escalation checks.
- Insertion sort: every comparison is logged with the key that decides, and the bars move.
- Ranks, deadlines and the top five; Download **CSV** (comma-separated values) saves priority_list.csv.
- Escalation checkbox: switch the rule off and watch R-06 and R-02 fall back to P2.
- Load my **CSV**: ranks your own Lab 3 register with the same method.

59

steps: classes, escalation checks, comparisons, ranks

3 Schematic 3 — from level to priority



Downloadable from the module (SVG or PNG), with the ranked list as **CSV** (comma-separated values).

Lab 2 — Threat catalogue — due tonight

- Due Saturday, November 14, 2026, at 23:59 (Montréal time, **EST** [Eastern Standard Time]) — Léa drop box (Omnivox).
- One ZIP · 5 % · individual.
- Last check: kalmia_threat_catalogue.py --check → zero rule errors; the report is inside the ZIP.
- Late policy: 10 % per day; not accepted after seven days.

23:59

tonight, Saturday, November 14 — Léa drop box

Lab 3 — Risk register and prioritization (summary)

- Register: at least 20 rows in the nineteen columns (the twelve seed rows completed and verified).
- Readiness: the eight-capability scorecard with evidence, and a readiness level per row.
- Matrix: the heat map from your register, with a short reading.
- Priorities: class, rank and deadline of every row; **ALE** (annualized loss expectancy) for the three to five highest risks.
- Checker: kalmia_risk_register.py your_file.csv --lab3 → READY TO SUBMIT · one-page top-five memo to Nadia Roy.
- Due Friday, November 20, 2026, 23:59 (**EST** [Eastern Standard Time], **UTC** [Coordinated Universal Time]−05:00) · Léa drop box · one ZIP · 5 %.

Nov 20

Friday, 23:59 (**EST** [Eastern Standard Time]) — Léa drop box

Recap — five sentences to keep

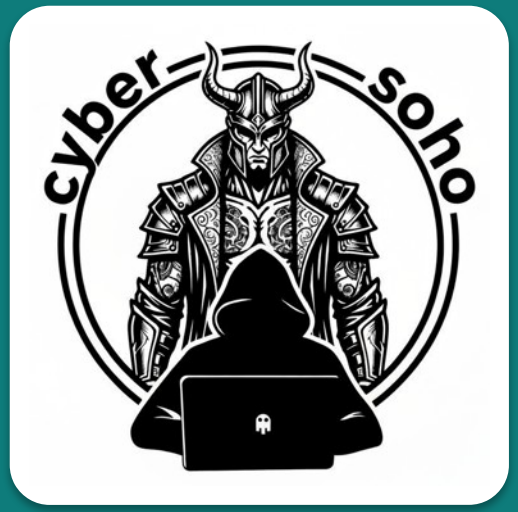
1. Response capability mainly changes impact: outage ≈ detect + contain + recover, compared with the **MTD** (maximum tolerable downtime).
2. Readiness is scored on evidence (0 absent → 3 tested); Kalmia today: 5/24, LOW.
3. The matrix shows the picture; the register keeps the reasons — L, I, justification, evidence, owner.
4. A priority is not a level: class, score, impact, criticality, evidence, readiness — in that order.
5. No owner, no rank, no decision: evidence · owner · rank.

evidence · owner · rank

the one fact of tonight

Key references (official sites — check each link on VirusTotal before clicking)

- **NIST** (National Institute of Standards and Technology, United States) **SP** (Special Publication) 800-61 Revision 3 — incident response (2025)
- Canadian Centre for Cyber Security — Developing your incident response plan
- LégisQuébec — Act respecting the protection of personal information in the private sector
- **NIST SP** 800-30 Revision 1 — Guide for Conducting Risk Assessments
- **NIST IR** (Interagency or Internal Report) 8286 Revision 1 — Cybersecurity and Enterprise Risk Management
- **NIST IR** 8286B — Prioritizing Cybersecurity Risk
- **CISA** (Cybersecurity and Infrastructure Security Agency, United States) — Known Exploited Vulnerabilities catalog
- **FIRST** (Forum of Incident Response and Security Teams) — **EPSS** (Exploit Prediction Scoring System) and **CVSS** (Common Vulnerability Scoring System)
- Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy (v2.0)



Thank you — see you in Hours 2 to 4

Next: Class 12 — Monday, November 16, 6:00 – 10:00 pm — Topic 6, Part 1: treatment options and types of controls

Lab 2 closes tonight at 23:59 · Lab 3 is due Friday, November 20, 2026, at 23:59 · Quiz 3 (Topics 1–5) on Monday is published separately.